API Penetration Testing Report

17th October, 2024

Level 1 Report

1.1 Copyright

The copyright in this work is vested in Cybertryzub Infosec Pvt. Ltd., and the document is issued in confidence for the purpose for which it is supplied. It must not be reproduced in whole or in part or used for tendering or manufacturing purposes except under agreement or with the consent in writing of Cybertryzub Infosec Pvt. Ltd. and then only on condition that this notice is included in any such reproduction. No information as to the contents or subject matter of this document or any part thereof arising directly or indirectly there from shall be given orally or in writing or communicated in any manner whatsoever to any third party being an individual firm or company or any employee thereof without the prior consent in writing of Cybertryzub Infosec Pvt. Ltd.

© Cybertryzub Infosec Pvt. Ltd.

1.2 Contact Information

Mrs. Jyoti Singh
CISA, CIPM, FIP, CIPP/E, ISO 27001
LA, DevOps, MSc, PG Data Science.
(InfoSec Lead Auditor)
+91 9873784553, 8295777275
info@cybertryzub.com

Corporate Office
PLOT NO 76D UDYOG VIHAR 4 SECTOR 18,
GURGAON – 122001
HARYANA, India

Registered Office
F-300, SECTOR 63, NOIDA-201301
UTTAR PRADESH, INDIA

2.0 About Us

Cybertryzub InfoSec Private Limited is an ISO Certified (ISO 27001:2013) company. Cybertryzub aims to provide Auditing; Consulting, Information Risk Management and Managed services tailored as per the market requirements and enhance the satisfaction and confidence index of its existing and potential customers.

Cybertryzub has been a CERT-In empaneled IT Security Auditor. It is an acknowledgement of Cybertryzub's technical expertise in conducting Information Security Audits. As a CERT-In empaneled auditor Cybertryzub is qualified to conduct security audits of websites, networks & applications. On successfully completing the audit as per CERT-In Guidelines, our team can issue the CERT-In Certification as required by compliance requirements.

From the development of a Security Policy, Security Awareness Training, through to the delivery of complete end-to-end solutions that encompass Perimeter Security, Secure Content Management, Identity and Access Management, Vulnerability Assessment, Risk, Policy and Compliance Management, Cybertryzub InfoSec Private Limited helps organizations understand, monitor and mitigate the risks in their IT infrastructure.

Cybertryzub InfoSec Private Limited has information security experts, compliance professionals and process consultants from different industry verticals with multiple certifications each with experience in handling consulting assignments, audits and training programs.

Cybertryzub InfoSec Consultants has established a reputation for providing practical solutions that are both businesses driven and cost-effective. This has enabled the company to secure the IT Infrastructure of leading Stock Brokers, Government undertakings, Banks, Insurance Companies and Financial Institutions, BPO, KPO, PKI Industry, Data Center, Software Company, Automobile, Healthcare & Life Sciences, Hospitality, Travel, Transportation, Consumer & Retail, Technology, Media & Telecommunication, School, College, Smart City. Security Leadership our experienced team of ethical hackers have identified security vulnerabilities, we have put together a highly qualified team of security researchers with credentials like CISA, CISSP, OSCP, CSOE, CCNP, MCSE+, ISO 27001 LA, ITIL, COBIT, CIPP/E, CIPM, FIS, DISA, CPA, Cyber Law, Data Science, Artificial Intelligence & Machine Learning, DevSecOps, AWS Architect, Azure Architect.

3.0 Table of Contents

1.0 1.1 Copyright 2
1.2 Contact Information.....2
2.0 About Us.....3
3.0 Table of Contents.....4
4.0 Assessment Information.....5
4.1 Assessment scope summary.....5
4.2 Client details.....5
4.3 Cybertryzub Infosec Pvt. Ltd. Details.....5
5.0 Process and Methodology.....6
6.0 Performed Tests.....6
7.0 Vulnerability Overview.....7
8.0 Executive Summary.....8
9.0 Summary vulnerabilities.....9
10.0 Detailed Findings and Recommendation.....10
11.0 High-Level Recommendations.....18

4.0 Assessment Information

4.1 Assessment Scope Summary

Engagement Type	Web Services Gray Box Assessment
Engagement Scope	https://preprod.api.crego.io
Engagement Timeframe	October 15th, 2024 to October 17th, 2024

4.2 Client Details

Organization	Crego
Contact Person	Abhishek Sharma
Email ID:	abhishek@crego.io
Telephone:	+91 9599976692

4.3 Cybertryzub Infosec Pvt. Ltd. Details

Auditor	Deepanshu Kumar
Review and Final Approval	Mrs. Jyoti Singh (CISA, CIPM, FIP, CIPP/E, ISO 27001 LA, DevOps, MSc, PG Data Science.)
Report ID:	
Report Type	Level 2 APIs report

5.0 Process and Methodology

Our Penetration Testing Methodology grounded on following guides and standards:

- Penetration Testing Execution Standard
- OWASP Top 10 Application Security Risks - 2017
- OWASP Testing Guide
- OWASP ASVS

6.0 Performed Tests

Criteria Label	Status
API1:2019 - Broken Object Level Authorization	**Meets criteria**
API2:2019 - Broken User Authentication	**Meets criteria**
API3:2019 - Excessive Data Exposure	**Meets criteria**
API4:2019 - Lack of Resources & Rate Limiting	**Meets criteria**
API5:2019 - Broken Function Level Authorization	**Meets criteria**
API6:2019 - Mass Assignment	**Meets criteria**
API7:2019 - Security Misconfiguration	**Meets criteria**
API8:2019 - Injection	**Meets criteria**
API9:2019 - Improper Assets Management	**Meets criteria**
API10:2019 - Insufficient Logging & Monitoring	**N/A**

7.0 Vulnerability Overview

Cybertryzub performed a web services security Assessment for **Crego** on **2024-10-15** to **2024-10-17** and revalidation test is yet to perform. This assessment utilized both commercial and proprietary tools for the initial mapping and reconnaissance of the network system as well as custom tools and scripts for unique vulnerabilities. Several attacking tools was used in order to conduct the penetration testing on the network.

VULNERABILITY RISK DEFINITION AND CRITERIA

The risk rating assigned to each vulnerability are determined by averaging several aspects of the exploit and the environment, including reputation, difficulty and impact.

Critical — Critical vulnerabilities pose a serious threat to an organization's security, and should be fixed immediately. They may provide a total compromise of the target environment, or similar critical impacts.

High — High risk vulnerabilities provide a serious risk to the company environment and should be corrected promptly. These issues can significantly affect the organization's security posture.

Medium — Medium severity vulnerabilities represent a moderate risk to the environment. They may require additional context before remediation but should be remediated after critical and high risks.

Low — Low severity vulnerabilities provide minimal risk to the target environment, and often theoretical in nature. Remediation of low risks is often a lower priority than other security hardening techniques.

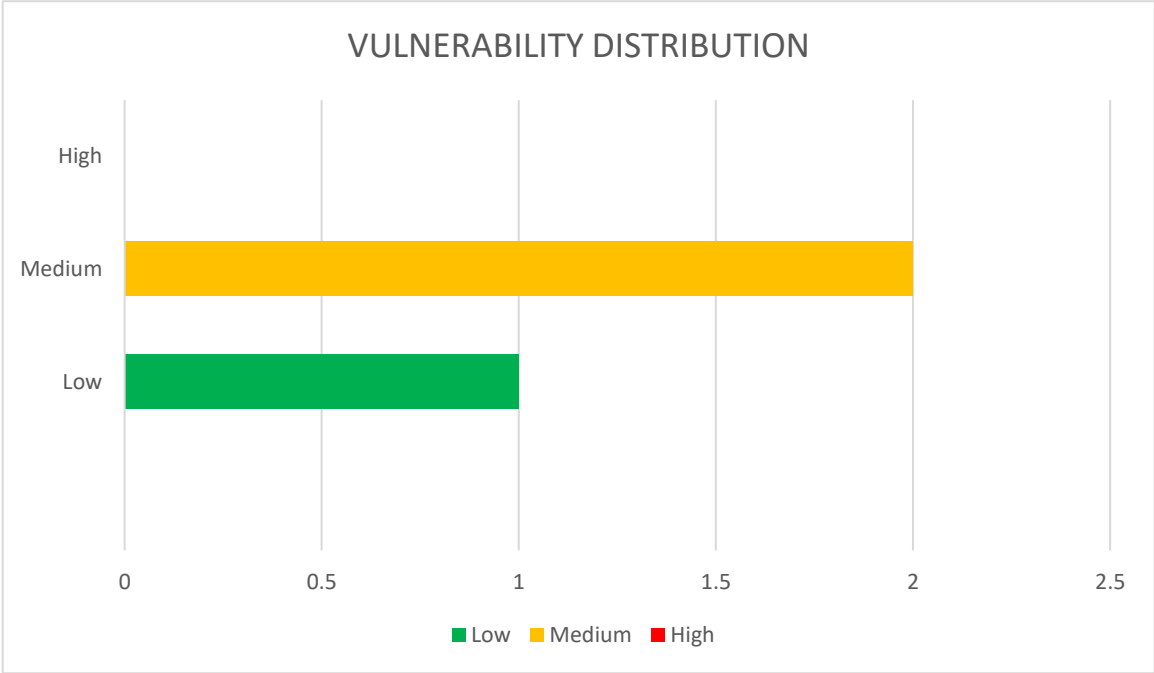
Informational — Informational vulnerabilities have little-or-no impact to the target scope by themselves. They are included however, as they may be a risk when combined with other circumstances or technologies not currently in place. Remediation of informational items is not necessary.

8.0 Executive Summary:

Based on the assessment carried out by Cybertryzub **15th October, 2024** from **17th October, 2024** following notable issues have been identified in reference to OWASP standards. This section provides a quick snapshot of the security posture for the Web Services.

Severity wise vulnerability distribution

	High	Medium	Low	Total
As per scope mentioned in section 4.1	**0**	**2**	**1**	**3**



9.0 Summary of Vulnerabilities

Based on the assessment carried out by Cybertryzub from **15/10/2024** to **17/10/2024** following notable issues have been identified in reference to OWASP standards. This section provides a quick snapshot of the security posture for the Web Services.

S/N	Vulnerability	Severity	Level 1 – 31/07/2024	Closure – 10/09/2024
1	**DEBUG enabled**	Medium	Open	Closed
2	**Business Logic Flaw: Accepting future start date**	Medium	Open	Closed
3	**Security Headers Missing**	Low	Open	Closed*

10.0 Detailed Findings and Recommendation

10.1 DEBUG enabled

Severity	Medium
Status	Closed

Proof of Concept

Request

Pretty Raw Hex

```
POST /v1/identity/auth/token/refresh/ HTTP/2
Host: preprod.api.crego.io
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71
Safari/537.36
Content-Type: application/x-www-form-urlencoded
Content-Length: 0
X-App-Name: Jupiter
Origin: https://preprod.jupiter.crego.io
Referer: https://preprod.jupiter.crego.io/
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-site
Te: trailers
```

Response

Pretty Raw Hex Render

```
HTTP/2 400 Bad Request
Date: Thu, 17 Oct 2024 06:37:47 GMT
Content-Type: application/json
Content-Length: 39
Server: gunicorn
Set-Cookie: AWSALB=
a4JTCdoarZUWkcppxZQkZbr6FlIN6KbegNy9mIi1VzszwTTQPkAXTeziP5PZPTnfCDaFwo0JVWuxh
42r3OrrSgAxfHa4yKWYi+ph3+DKp2Izmlkw5LfKNlAh59Ei; Expires=Thu, 24 Oct 2024
06:37:47 GMT; Path=/
Set-Cookie: AWSALBCORS=
a4JTCdoarZUWkcppxZQkZbr6FlIN6KbegNy9mIi1VzszwTTQPkAXTeziP5PZPTnfCDaFwo0JVWuxh
42r3OrrSgAxfHa4yKWYi+ph3+DKp2Izmlkw5LfKNlAh59Ei; Expires=Thu, 24 Oct 2024
06:37:47 GMT; Path=/; SameSite=None
Allow: POST, OPTIONS
Vary: origin
X-Content-Type-Options: nosniff
Referrer-Policy: same-origin
Cross-Origin-Opener-Policy: same-origin
Access-Control-Allow-Origin: https://preprod.jupiter.crego.io
Access-Control-Expose-Headers: content-disposition
Apigw-Requestid: fyCNXh8qhcwEPyA=

{"refresh":["This field is required."]}
```

Proof of Concept 10.1.1

10.2 Business Logic Flaw: Accepting future start date

Severity	**Medium**
Status	**Closed**

Proof of Concept

Request

Pretty Raw Hex JSON Web Tokens

```
1  PUT /v1/gl/transactions/collection_report/ HTTP/2
2  Host: preprod.api.crego.io
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Sec-Fetch-Dest: empty
8  Sec-Fetch-Mode: cors
9  Sec-Fetch-Site: same-site
10 Priority: u=0
11 Te: trailers
12 Authorization: Bearer
   eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzI5MTQ2NjUxLCJpYXQiOjE3M
   jkxNDMwNTEsImp0aSI6IjMwNzg3OWYyOTgyYTQxZTQ5Njg0NTIwOWZmMWY3YzMwIiwidXNlcl9pZCI6ImE3YzE1ODAzLTg1MzUtNDc
   4OC1hNmU3LTNjMzVlNjhkMzI0MCIsImNvbXBhbnlfaWQiOiIxNWMzOTg4Ni1hMDRlLTQ5ZWYtODQ1Zi05Y2Q5YzM0ZjFjNjIiLCJlc
   2VybmFtZSI6ImluZGlmaV9hZG1pbiIsImFjY2Vzc190eXBlIjoianVwaXRlciIsInR5cGUiOiJsZW5kZXIifQ.ylGCxVx2r0bVKmMG
   A9FSPsDHU3JVatUsB11-6ZRvmtI
13 Content-Type: application/json
14 Content-Length: 125
15
16 {
17   "download_excel":false,
18   "filter_on":"date",
19   "start_date":2530742400,
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 404 Not Found
2 Date: Thu, 17 Oct 2024 05:40:18 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 9
5 Server: awselb/2.0
6 Apigw-Requestid: fx5yXgjrBcwEMIg=
7
8 Not found
```

Proof of Concept 10.2.1

Request

Pretty | Raw | Hex | JSON Web Tokens

```
1  PUT /v1/gl/transactions/disbursement_report/ HTTP/2
2  Host: preprod.api.crego.io
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Sec-Fetch-Dest: empty
8  Sec-Fetch-Mode: cors
9  Sec-Fetch-Site: same-site
10 Priority: u=0
11 Te: trailers
12 Authorization: Bearer
   eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzI5MTQ2NjUxLCJ
   pYXQiOjE3MjkxNDMwNTEsImp0aSI6IjMwNzg3OWYyOTgyYTQxZTQ5Njg0NTIwOWZmMWY3YzMwIiwidXNlcl9pZCI6ImE
   3YzElODAzLTg1MzUtNDc4OClhNmU3LTNjMzVlNjhkMzI0MCIsImNvbXBhbnlfaWQiOiIxNWMzOTg4NilhMDRlLTQ5ZWY
   tODQ1Zi05Y2Q5YzM0ZjFjNjIiLCJlc2VybmFtZSI6ImluZGlmaV9hZG1pbiIsImFjY2Vzc190eXBlIjoianVwaXRlciI
   sInR5cGUiOiJsZW5kZXIifQ.ylGCxVx2r0bVKmMGA9FSPsDHU3JVatUsBl1-6ZRvmtI
13 Content-Type: application/json
14 Content-Length: 122
15
16 {
17   "download_excel":false,
18   "filter_on":"date",
19   "start_date":2530742400,
```

Response

Pretty | Raw | Hex | Render

```
1 HTTP/2 404 Not Found
2 Date: Thu, 17 Oct 2024 05:41:29 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 9
5 Server: awselb/2.0
6 Apigw-Requestid: fx59gj_6hcwEMBQ=
7
8 Not found
```

Proof of Concept 10.2.2

Request

Pretty | Raw | Hex | JSON Web Tokens

```
1  PUT /v1/gl/transactions/download_excel/ HTTP/2
2  Host: preprod.api.crego.io
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Sec-Fetch-Dest: empty
8  Sec-Fetch-Mode: cors
9  Sec-Fetch-Site: same-site
10 Priority: u=0
11 Te: trailers
12 Authorization: Bearer
   eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzI5MTQ2NjUxLCJpYXQiO
   jE3MjkxNDMwNTEsImp0aSI6IjMwNzg3OWYyOTgyYTQxZTQ5Njg0NTIwOWZmMWY3YzMwIiwidXNlcl9pZCI6ImE3YzElODAzLTg
   1MzUtNDc4OC1hNmU3LTNjMzVlNjhkMzI0MCIsImNvbXBhbnlfaWQiOiIxNWMzOTg4NilhMDRlLTQ5ZWYtODQ1Zi05Y2Q5YzM0Z
   jFjNjIiLCJlc2VybmFtZSI6ImluZGlmaV9hZG1pbiIsImFjY2Vzcl90eXBlIjoianVwaXRlciIsInR5cGUiOiJsZW5kZXIifQ.
   ylGCxVx2r0bVKmMGA9FSPsDHU3JVatUsBl1-6ZRvmtI
13 Content-Type: application/json
14 Content-Length: 122
15
16 {
17   "download_excel":false,
18   "filter_on":"date",
19   "start_date":2530742400,
```

Response

Pretty | Raw | Hex | Render

```
1 HTTP/2 404 Not Found
2 Date: Thu, 17 Oct 2024 05:42:28 GMT
3 Content-Type: text/plain; charset=utf-8
4 Content-Length: 9
5 Server: awselb/2.0
6 Apigw-Requestid: fx6GwhHrBcwEMbQ=
7
8 Not found
```

Proof of Concept 10.2.3

Request

Pretty | Raw | Hex | JSON Web Tokens

```
1  PUT /v1/gl/transactions/charge_summary/ HTTP/2
2  Host: preprod.api.crego.io
3  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0) Gecko/20100101 Firefox/129.0
4  Accept: */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Sec-Fetch-Dest: empty
8  Sec-Fetch-Mode: cors
9  Sec-Fetch-Site: same-site
10 Priority: u=0
11 Te: trailers
12 Origin: https://preprod.jupiter.crego.io
13 Authorization: Bearer
   eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ0b2tlbl90eXBlIjoiYWNjZXNzIiwiZXhwIjoxNzI5MTQ2NjUxLCJpYXQ
   iOjE3MjkxNDMwNTEsImp0aSI6IjMwNzg3OWYyOTgyYTQxZTQ5Njg0NTIwOWZmMWY3YzMwIiwidXNlcl9pZCI6ImE3YzE1ODA
   zLTglMzUtNDc4OC1hNmU3LTNjMzVlNjhkMzI0MCIsImNvbXBhbnlfaWQiOiIxNWMzOTg4NilhMDRlLTQ5ZWYtODQ1Zi05Y2Q
   5YzM0ZjFjNjIiLCJlc2VybmFtZSI6ImluZGlmaV9hZGlpbiIsImFjY2Vzcl90eXBlIjoianVwaXRlciIsInR5cGUiOiJsZW5
   kZXIifQ.ylGCxVx2r0bVKmMGA9FSPsDHU3JVatUsB11-6ZRvmtI
14 Content-Type: application/json
15 Content-Length: 113
16
17 {
18     "download_excel": false,
19     "filter_on": "date", "start_date": 2530742400, "end_date":  2531260800
```

Response

Pretty | Raw | Hex | Render

```
1  HTTP/2 404 Not Found
2  Date: Thu, 17 Oct 2024 05:43:54 GMT
3  Content-Type: text/plain; charset=utf-8
4  Content-Length: 9
5  Server: awselb/2.0
6  Apigw-Requestid: fx6UNhoKhcwEMZw=
7  Access-Control-Allow-Origin:
   https://preprod.jupiter.crego.io
8  Vary: origin
9  Access-Control-Expose-Headers:
   content-disposition
10
11 Not found
```

Proof of Concept 10.2.4

10.3 Security Headers Missing

Severity	**Low**
Status	**Closed*** As per client "Requesting you to consider "Security Headers Missing" in API report as exception and I will make sure this gets closed in upcoming cycle."
Proof of Concept	

11.0 High-Level Recommendations

Taking into consideration all issues that have been discovered, we highly recommend to:

- Conduct current vs. future IT/Security program review
- Conduct Static code analysis for codebase
- Establish Secure SDLC best practices, assign Security Engineer to a project to monthly review code, conduct SAST & DAST security testing
- Review Architecture of application
- Deploy Web Application Firewall solution to detect any malicious manipulations
- Continuously monitor logs for anomalies to detect abnormal behavior and fraud transactions. Dedicate security operations engineer to this task
- Implement Patch Management procedures for whole IT infrastructure and endpoints of employees and developers
- Continuously Patch production and development environments and systems on regular bases with latest releases and security updates
- Conduct annual Penetration test and quarterly Vulnerability Scanning against internal and external environment
- Develop and Conduct Security Awareness training for employees and developers
- Develop Incident Response Plan in case of Data breach or security incidents
- Analyze risks for key assets and resources
- Update codebase to conduct verification and sanitization of user input on both, client and server side
- Use only encrypted channels for communications
- Do not send any unnecessary data in requests and cookies
- Improve server and application configuration to meet security best practices